Networking and Security Revision

IE3122 – Network Security | Week 2

The threat landscape: actors, attacks, and defenses

Today's Agenda

- Why network security matters
- Key terms and threat modeling
- How networking — and its threats — have evolved
- Types of hackers and their motivations
- Main types of attacks
- Security controls and layered defense

Learning Outcomes for Today

LO1

- Describe common network vulnerabilities and attacks.

LO3

- Analyse a company's network and communication requirements and communicate security requirements.

- *By the end of this session you should be able to name the major categories of attackers and attacks, and explain why layered defense matters — the foundation for everything from Week 3 onward.*

Why Network Security Matters

Setting the stage

What Is Network Security?

- The practice of protecting the confidentiality, integrity, and availability of data as it moves across and is stored on a network.
- Covers people, process, and technology — not just firewalls and passwords.
- Applies at every layer we revised in Week 1: physical cabling, switches/routers, protocols, and the applications running on top.
- This module builds toward being able to identify weaknesses (LO1) and recommend/configure defenses (LO2, LO4, LO5).

Why It Matters

- Modern organisations run on networks — a compromised network can mean stolen data, halted operations, financial loss, and reputational damage.
- Attacks aren't rare or abstract: recall the real 2025–2026 breaches from Week 1's lab (retail ransomware, VPN zero-days, exposed devices, vendor breaches).
- Security is not a one-time setup — the threat landscape keeps changing, which is exactly why this lecture exists before we get into specific technologies.
- As a future network/security professional, understanding *why* an attack works is what lets you recommend the right defense — not just follow a checklist.

The Extended CIA Triad

Fundamental Information Security Controls

The CIA Triad

Confidentiality	Integrity	Availability
Only authorised people/systems can access the data	Data is accurate and hasn't been altered without authorisation	Data and systems are accessible to legitimate users when needed

- The CIA Triad is the foundational model for what ‘security’ actually means — almost every control we cover this semester protects one or more of these three properties.
- An attack usually targets one corner specifically: theft/eavesdropping breaks confidentiality, tampering breaks integrity, and a DoS/DDoS attack breaks availability.
- Trade-offs are common — stronger confidentiality controls (e.g. heavy encryption, strict access checks) can sometimes reduce availability if overdone. Good security design balances all three, not maximises one.

Authentication

- Authentication answers one question: is this person/device really who they claim to be?
- It's distinct from authorisation (what you're allowed to do once verified) — authentication comes first.
- Three general factor categories: something you know (password, PIN), something you have (a token, a phone, a smart card), something you are (biometrics — fingerprint, face).
- Multi-Factor Authentication (MFA) combines two or more of these categories — significantly harder to defeat than any single factor alone, since compromising a password alone is no longer enough.
- This is a preview: we'll cover authentication systems (RADIUS, TACACS+) in full under AAA in Week 8 — for now, just recognise it as one of the core security principles everything else builds on.

Non-Repudiation

- Non-repudiation means a party can't credibly deny having performed an action — sent a message, approved a transaction, accessed a system — once there's verifiable proof they did.
- It's what makes an action accountable after the fact, not just secure in the moment — confidentiality and integrity protect the data itself, non-repudiation protects the record of who did what.
- Achieved through mechanisms like digital signatures and audit logging — a digital signature cryptographically ties an action to a specific identity in a way that identity can't later disown.
- Real-world relevance: this is why financial transactions, legal documents, and security-critical system changes rely on digitally signed records rather than just usernames in a log file.
- Another preview: we'll cover the cryptographic mechanisms behind this — hash functions, digital certificates, PKI — in full in Week 12.

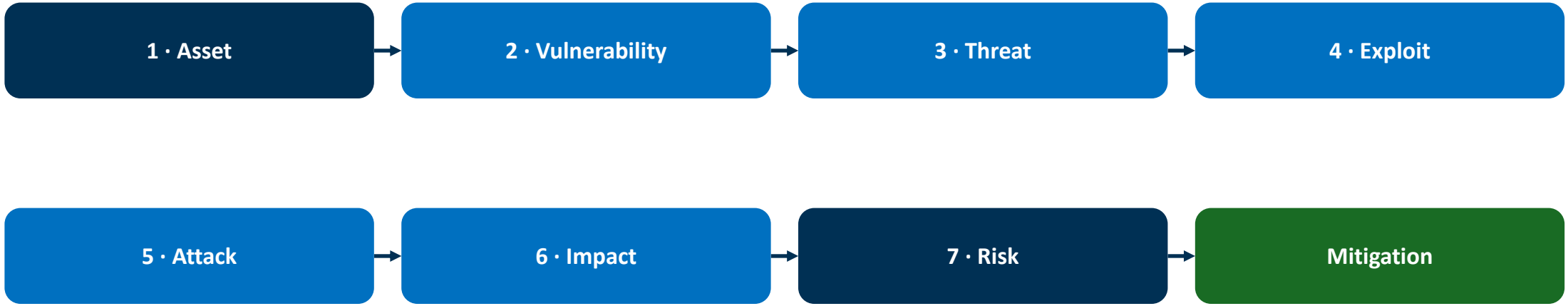
Key Terms & Threat Modeling

The vocabulary we'll use all semester

Key Terms — Revision

Term	Meaning
Asset	Anything of value worth protecting — data, a server, a service, even reputation
Vulnerability	A weakness that could be exploited (a bug, misconfiguration, missing patch)
Threat	Anything with the potential to exploit a vulnerability and cause harm
Exploit	The specific method/tool used to take advantage of a vulnerability
Attack	The actual event of a threat using an exploit against a vulnerability
Impact	The real-world consequence of a successful attack — data loss, downtime, cost
Risk	The likelihood and impact of a threat actually exploiting a vulnerability
Mitigation	The control or action taken to reduce a vulnerability, threat, or its impact

How These Terms Fit Together



- Read left-to-right, top row then bottom row: a threat uses an exploit against a vulnerability to carry out an attack, which causes an impact — together these determine the risk.
- Mitigation is the response: a control that reduces the vulnerability, blocks the exploit, or limits the impact — lowering the overall risk.
- Risk is what security professionals actually manage — you can rarely eliminate every vulnerability, so you prioritise mitigations by risk.

What Is Threat Modeling?

- A structured way of asking: what are we protecting, who might attack it, how might they do it, and what should we do about it?
- A simple, repeatable process: identify assets → identify likely threats → assess vulnerabilities → prioritise and mitigate by risk.
- This is exactly the reasoning LO3 asks of you — analyzing a company's network/communication requirements starts with a threat model, not a product list.
- We'll come back to this process every time we look at a new attack category or technology for the rest of the module.

Worked Example: A Small Online Retailer

Step	Applied to this company
Asset	Customer payment data, the order-processing database
Vulnerability	Unpatched web server, weak admin password policy
Threat	Financially motivated attackers (black hats, criminal groups)
Exploit	A known, unpatched web-server vulnerability with public exploit code available
Attack	Attackers use the exploit to gain admin access and copy the payment database
Impact	Stolen customer payment data, regulatory fines, loss of customer trust
Risk	High — valuable data + known weaknesses + attackers actively interested
Mitigation	Patch the web server promptly, enforce strong admin passwords + MFA, encrypt stored data

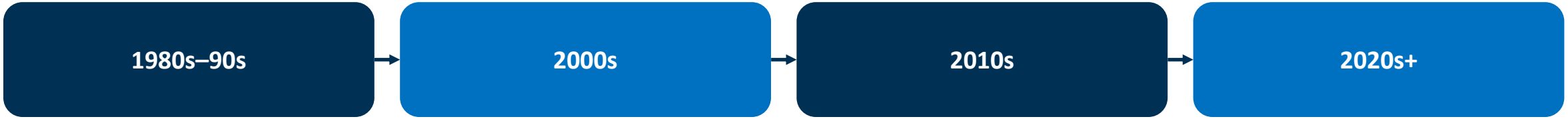
This is the exact reasoning you'll apply in this week's lab — and in the group assignment later in the semester.

How Networking — and Its Threats — Have Evolved

Same principles, a much bigger attack surface

EVOLUTION

From Isolated Systems to Everything Connected



Isolated LANs

Physical access was the main risk

Internet-connected

Remote attacks become possible

Cloud & mobile

Data leaves the building; more entry points

IoT & remote work

Billions of devices, no fixed perimeter

The Threat Landscape Evolved Alongside It

- More connectivity has always meant more attack surface — every new capability (remote access, cloud storage, IoT sensors) is also a new way in.
- Attacks have professionalised: from lone hobbyists to organised criminal groups, data brokers, and state-sponsored operations (more on this shortly).
- The targets have changed too — attackers now go after cloud misconfigurations, VPN appliances, and supply-chain/vendor relationships, not just a single office firewall (recall Week 1's Ivanti VPN and SonicWall vendor-breach case studies).
- The core lesson: the fundamentals we revised in Week 1 (layers, protocols) still apply — but the scale and sophistication of who's attacking them has grown enormously.

Types of Hackers

Knowing who you're defending against

Hackers Aren't All the Same

- ‘Hacker’ just means someone with the skill to find and exploit weaknesses in a system — it says nothing about their intent.
- Understanding who's likely to target a given organisation is part of LO3's ‘analyse requirements’ — a bank and a small blog face very different threat actors.
- Two common ways to categorise attackers: the ‘hat’ spectrum (intent/ethics) and role-based categories (how they operate or who they work for).

The Hat Spectrum

Hat	Who they are
White Hat	Ethical hackers authorised to test systems and report weaknesses
Black Hat	Malicious attackers exploiting systems for personal or financial gain
Grey Hat	Find vulnerabilities without permission but without malicious intent — legally ambiguous
Blue Hat	Security professionals (often external/outsourced) who test an organisation's own systems
Red Hat	Aggressively target black hats directly, sometimes using illegal methods themselves
Green Hat	Newcomers still learning — enthusiastic but limited skill, can cause accidental harm

Beyond the Hats

Category	What defines them
Script Kiddies	Little technical skill — run existing tools/scripts written by others
Access & Data Brokers	Sell stolen access or data to other attackers rather than exploiting it themselves
State-Sponsored Hackers	Funded by governments; highly resourced, target high-value/strategic systems
Hacktivists	Motivated by political or social causes, not money — aim to expose or disrupt

These aren't mutually exclusive with the hat spectrum — a state-sponsored hacker, for instance, is still operating with black-hat intent.

Key Motivations

Financial gain	Ransomware, fraud, selling stolen data
Ideology / politics	Hacktivism — expose or disrupt a cause's opponents
Espionage	State-sponsored theft of intelligence or IP
Revenge	Targeting a specific person or organisation
Curiosity / challenge	Proving a skill, sometimes with no clear malicious goal

Main Types of Attacks

Malware, social engineering, DoS/DDoS, and reconnaissance

Four Broad Attack Categories

Malware

Malicious software that runs on a target system

Social Engineering

Manipulating people rather than exploiting code

DoS / DDoS

Overwhelming a system so legitimate users can't use it

Access & Reconnaissance

Gathering information or gaining unauthorised entry

Malware: The Basics

- Malware = ‘malicious software’ — any program designed to damage, disrupt, or gain unauthorised access to a system.
- Delivered via email attachments, malicious downloads, infected removable media, or exploiting a software vulnerability directly.
- Different malware types are defined by *how they spread* and *what they do* once they're running — both matter for choosing a defense.

Malware Types (1/3)

Type	How it behaves
Virus	Attaches to a legitimate file/program; spreads when that file is run or shared
Worm	Self-replicating; spreads across a network on its own, no user action needed
Trojan	Disguised as legitimate software; relies on the user installing it themselves

Malware Types (2/3)

Type	How it behaves
Ransomware	Encrypts the victim's files/systems and demands payment for the decryption key
Spyware	Secretly monitors activity and exfiltrates data (keystrokes, credentials, browsing)
Rootkit	Hides deep in the system to maintain long-term, privileged, hard-to-detect access

Real-world example: WannaCry (2017) was ransomware that spread using a worm-like mechanism — a reminder that these categories often combine in a single real attack.

Malware Types (3/3)

Type	How it behaves
Adware	Automatically displays or downloads unwanted advertising; often bundled with free software
Keylogger	Records keystrokes to capture passwords, card numbers, and other sensitive input
Bot / Botnet malware	Enrolls an infected device into a remotely controlled network of ‘bots’ (recall Mirai) used for DDoS, spam, or further attacks
Logic Bomb	Malicious code that lies dormant until triggered by a specific condition or date

Social Engineering: The Basics

- Attacks that manipulate people rather than exploiting a technical flaw — often the easiest way into an otherwise well-defended network.
- Exploits trust, urgency, authority, or fear — recall Week 1's UK retail ransomware case, which began with a help-desk social-engineering compromise, not a technical exploit.
- This is exactly why LO1's ‘network vulnerabilities and attacks’ has to include people and process, not just code and configuration.

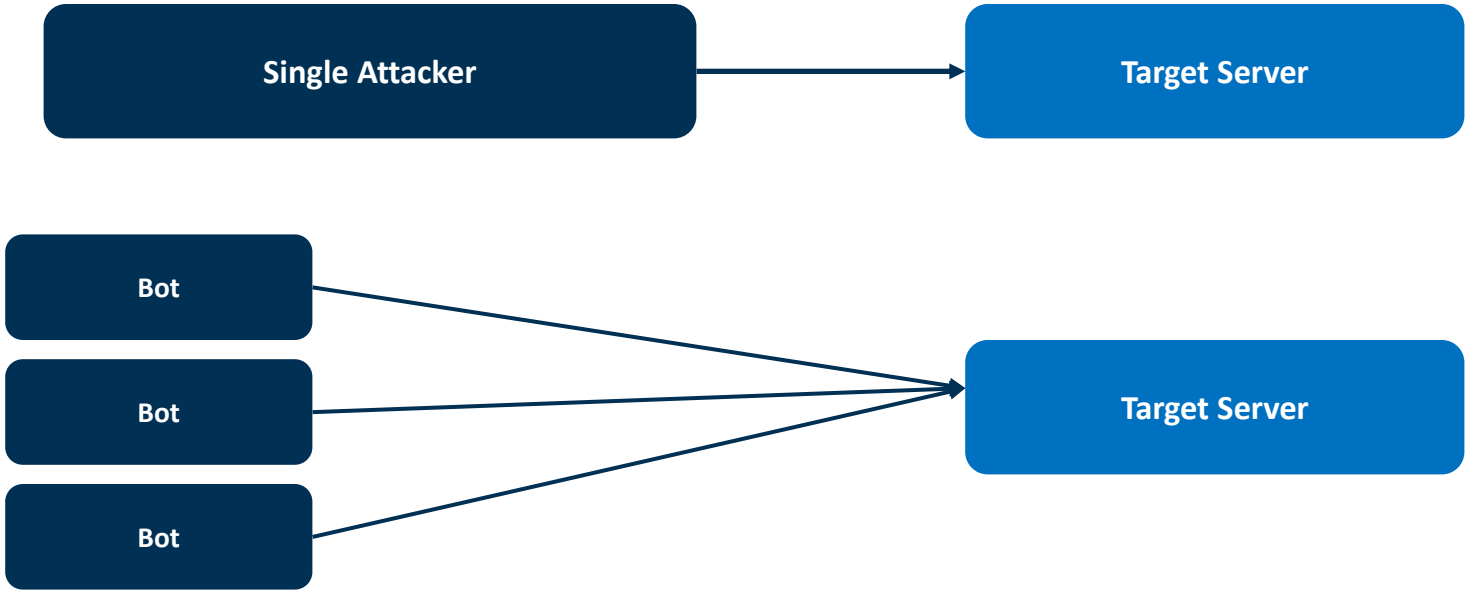
Social Engineering Attack Types (1/2)

Type	How it works
Phishing	Fraudulent email/message impersonating a trusted source to steal credentials or install malware
Spear Phishing	Phishing tailored to a specific individual or organisation using researched personal details
Whaling	Spear phishing targeted specifically at senior executives or other high-value individuals
Smishing	Phishing delivered via SMS/text message rather than email
Vishing	Voice-call version of phishing — often impersonating a bank or help desk

Social Engineering Attack Types (2/2)

Type	How it works
Pretexting	Inventing a false scenario/identity to obtain information (e.g. posing as IT support)
Baiting	Offering something enticing (free download, USB drive) that delivers malware when used
Quid Pro Quo	Offering a fake service or benefit (e.g. ‘free IT support’) in exchange for information or access
Tailgating / Piggybacking	Physically following an authorised person into a restricted area
Shoulder Surfing	Directly observing someone entering a password or PIN, or viewing sensitive info on their screen

DoS and DDoS



DoS — one source overwhelms the target

DDoS — many distributed bots (a botnet) flood the target at once

Goal: exhaust bandwidth, processing power, or connection limits so legitimate users can't get through — an attack on Availability.

DoS/DDoS: Real-World Examples

- Mirai botnet (2016): malware infected huge numbers of insecure IoT devices (cameras, routers) and used them to launch massive DDoS attacks, including one that took down major internet services via a DNS provider.
- GitHub (2018): hit by one of the largest recorded DDoS attacks at the time, peaking at 1.35 Tbps — mitigated through a dedicated DDoS-protection service.
- The common thread: DDoS scales with however many devices an attacker can compromise — which is why insecure IoT devices are such an attractive target.

Access & Reconnaissance Attacks

- Reconnaissance: gathering information about a target before attacking — scanning for open ports, mapping network topology, identifying software versions.
- Access attacks: attempts to gain unauthorised entry to a system or account once a weakness is found.
- Often the *first phase* of a larger attack — recon tells an attacker where to focus, access attacks get them in the door.

Access & Reconnaissance: Examples

Technique	What it does
Port scanning	Probes a host for open ports/services to identify potential entry points
Password/credential attacks	Brute-force or dictionary attacks, or reusing credentials leaked elsewhere (credential stuffing)
Footprinting	Passively gathering public info about a target (DNS records, employee info, tech stack)
Man-in-the-Middle	Intercepting communication between two parties, often after gaining network access

Security Controls & Layered Defense

No single control stops everything

Types of Security Controls

Category	Examples
Administrative	Policies, training, background checks, security awareness programs
Technical	Firewalls, encryption, access control lists, IDS/IPS (later weeks)
Physical	Locked server rooms, badge access, security cameras, cable locks

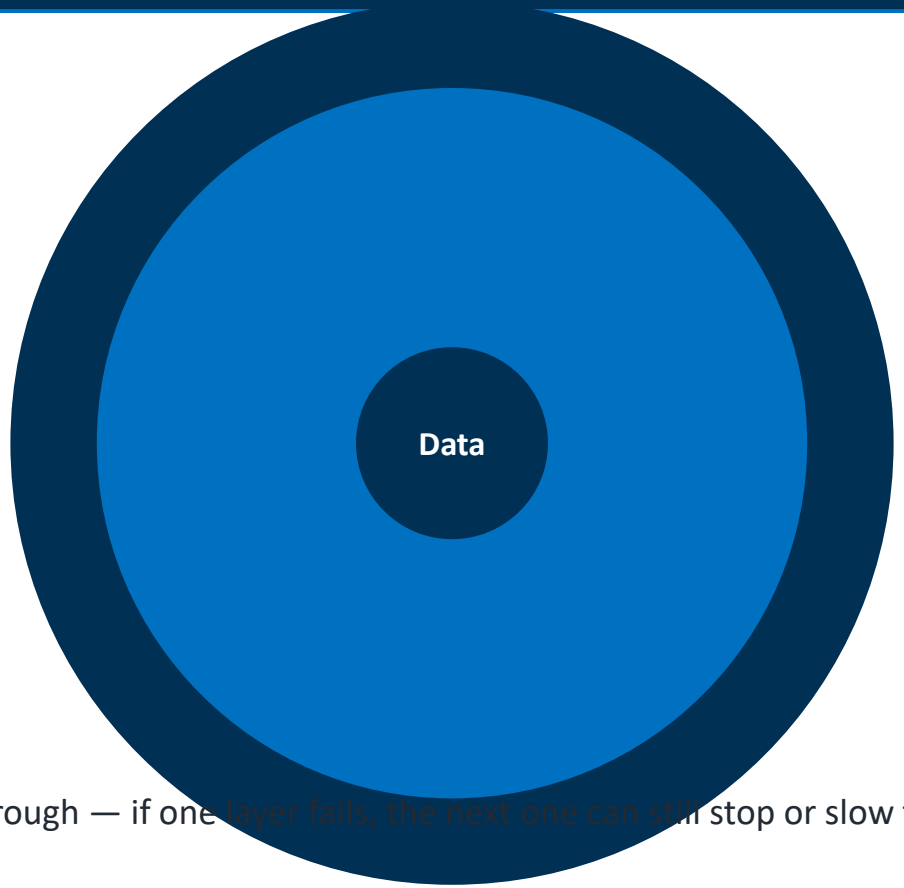
Controls by Function

Function	Purpose
Preventive	Stop an incident before it happens (e.g. firewall rules, training)
Deterrent	Discourage an attack without necessarily stopping it (e.g. warning banners, visible cameras)
Detective	Identify an incident that's happening or already happened (e.g. logging, IDS)
Corrective	Actively fix the immediate problem once detected (e.g. quarantining infected hosts, patching)
Recovery	Restore systems, data, and operations to normal after an incident (e.g. backups, disaster recovery plans)
Compensating	An alternative control used when the ideal control isn't feasible (e.g. extra monitoring where patching isn't yet possible)

Corrective and Recovery are related but distinct: corrective stops the bleeding, recovery gets you back to normal.

Defense in Depth

Perimeter → Network → Host → App → Data



Each ring is a control an attacker must get through — if one layer fails, the next one can still stop or slow them down.

Why Layered Defense Matters

- No single control stops every attack category we covered today — a firewall doesn't stop phishing; security training doesn't stop a DDoS flood.
- Layering different control types (administrative + technical + physical, preventive + detective + corrective) means one failure doesn't mean total compromise.
- This is the mindset the rest of the module builds on: each remaining technology (firewalls, AAA, VPN, IPS/IDS, cryptography) is one layer in this bigger picture, not a silver bullet on its own.

Matching Controls to Today's Attack Categories

Attack category	Controls that help (preview)
Malware	Technical: endpoint protection, patching. Administrative: safe-download policy.
Social engineering	Administrative: security-awareness training. Technical: email filtering.
DoS / DDoS	Technical: rate limiting, DDoS-protection services, redundant capacity.
Access & reconnaissance	Technical: firewalls, strong authentication (AAA, Week 8). Detective: logging/IDS (Week 10).

This mapping is exactly what this week's lab asks you to build for a scenario company — no need to memorise it, just understand the logic.

Summary

- Network security protects confidentiality, integrity, and availability — and depends on people and process as much as technology.
- Threat modeling (asset → threat → vulnerability → risk) is the reasoning behind every security decision we'll make this semester.
- Threat actors range from curious green hats to organised, state-sponsored operations — and their motivations shape what they target.
- Attacks fall into four broad categories: malware, social engineering, DoS/DDoS, and access/reconnaissance — often combined in a real incident.
- No single control is enough — layered defense across administrative, technical, and physical controls is the foundation for everything from Week 3 onward.

This Week's Lab & Tutorial

- Lab (runs in the Week 3 session, based on this lecture): a combined exercise — classify real incidents by threat-actor type and attack category, then design a layered-defense control set for a scenario company.
- Tutorial worksheet: 12 study-notes-style questions covering today's terms, threat actors, attack types, and controls — use it to prep for the mid-semester test.

References

- Kaufman, Perlman, Speciner & Perlner, Network Security: Private Communication in a Public World, 3rd Ed., Prentice Hall.
- Santos & Stuppi, CCNA Security 210-260 Official Cert Guide, 1st Ed., Cisco Press.
- Cisco Networking Academy — Introduction to Cybersecurity / CCNA Security curriculum.